쿠버네티스 환경에서 발생 가능한 보안 위협 분석

우승찬*, 이종혁*
*프로토콜공학연구실, 세종대학교
{seungchan, jonghyouk}@pel.sejong.ac.kr

Analysis of Possible Security Threats in Kubernetes Environment

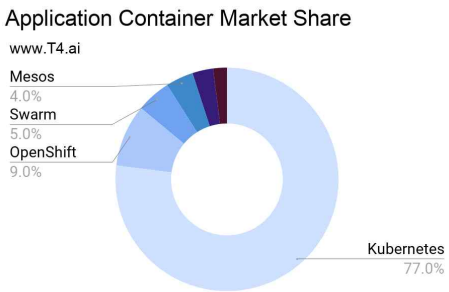
Seungchan Woo* Jong-Hyouk Lee*
*Protocol Engineering Lab., Sejong University

요 약

오늘날 개발자들은 효율적인 개발 환경 구성을 위해 컨테이너 기술을 널리 사용하고 있다. 컨테이너의 효율적인 관리를 위하여 컨테이너 오케스트레이터라고 하는 COE(Container Orchestration Engine)가 등장하였고, 이 중 쿠버네티스는 가장 많은 점유율을 차지하고 있다. 또한, 공격자들은 쿠버네티스 환경을 공격대상으로 하여 다양한 보안 위협을 가하고 있다. 이에 따라, 본 논문에서는 쿠버네티스 환경에서 발생할 수 있는 보안 위협을 분석하여 분류하고 발생 가능한 공격에 대해 설명한다.

I. 서론

오늘날 개발자들은 효율적인 개발 환경을 위하여 가상화 기술을 사용하고 있다. 이 중 컨테이너는 격리된 프로세스들이 가상화 환경에서 동작할 수 있도록 하는 기술로 호스트 OS와 커널을 공유한다. 기존에 사용하던 가상 머신보다 경량화되고 리소스를 적게 사용하기 때문에 개발자들은 컨테이너 기술 사용을 선호하고 있다. 컨테이너 기술의 대표적인 도구인 도커는 개발자 커뮤니티인 스택 오버플로의 설문조사에 따르면, 개발자의 55%가 도커를 사용하고, 76%가 도커를 선호한다고 밝혔다[1]. 이로 인해 도커 관리 문제가 대두되고 있는 실정이다. 즉, 컨테이너 통제, 조정 등과 같은 여러 조치들을 해결할 수 있는 방안이 필요하게 되었고 컨테이너 오케스트레이터인 COE(Container Orchestration Engine)가 등장하였다. 대표적인 COE 중에는 도커를 기반으로 하는 다양한 엔진들이 존재하며 쿠버네티스는 컨테이너 플랫폼 시장 점유율에서 77%의 점유율을 차지하였고 점점 더 늘어나고 있는 추세이다[2].



(그림 1) 컨테이너 플랫폼 시장 점유율

오케스트레이터 시장이 점점 더 커지고 쿠버네티스 플랫폼의 사용자가 증가함에 따라, 쿠버네티스 환경에서 발생 가능한 보안 위협 분석이 필요할 것으로 예상된다. 본 논문에서는 쿠버네티스 환경에서 발생할 수 있는 보안 위협을 분석한다. 논문의 구성은 다음과 같다. 2장에서는 도커 컨테이너와 쿠버네티스에 관해 설명한다. 3장에서는 쿠버네티스 환경에서 발생 가능한 보안 위협에 대해 분석한 내용을 설명한다. 끝으로 4장에선 본 논문의 결론 및 향후 연구 방향에 대하여 설명한다.

II. 관련 연구

2.1 도커 컨테이너

도커(Docker)는 컨테이너(Container)를 실행하고 관리하는 오픈소스 플랫폼으로써, 격리된 환경에서 애플리케이션을 패키징하고 실행할 수 있는 기능을 제공한다. 주어진 호스트에서 동시에 많은 컨테이너화 된 서비스를 실행할 수 있는 플랫폼이다. 도커는 컨테이너를 만들기 위한 파일과 설정값들을 포함한 도커 이미지를 사용한다. 자신만의 이미지를 만들거나 다른 사람이 저장소에 게시한 이미지를 컨테이너화 하여 사용 할 수 있다.

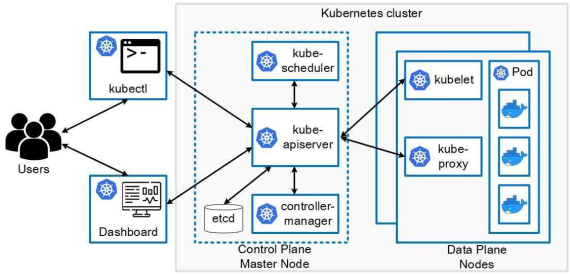
2.2 쿠버네티스

쿠버네티스(Kubernetes)는 컨테이너화된 워크로드와 서비스를 관리하기 위한 확장 가능한 오픈소스 플랫폼이다. 쿠버네티스는 여러 가지 기능을 제공하는데 해당 기능은 [표 1]과 같다.

[표 1] 쿠버네티스 기능

기능	설명
네트워크 트래픽 관리	컨테이너에 대한 네트워크 트래픽이 많으면 트래픽을 밸런싱하여 배포
저장소 오케스트레이션	사용자가 원하는 저장소 시스템 자동 탑재 가능
자동화 롤아웃/롤백	배포된 컨테이너를 원하는 상태로 자동화하여 유지
자동화 빈 패킹	컨테이너를 노드에 맞추어 효율적으로 리소스를 분배
자동화 복구	드랍된 컨테이너를 다시 시작하고 자동으로 컨테이너를 교체
민감한 정보 관리	비밀번호, SSH 키와 같은 정보를 저장하고 관리

[표 1]의 기능들을 통해 컨테이너 워크로드를 효율적으로 관리할 수 있으며 쿠버네티스를 배포할 경우, 클러스터가 생성된다. 클러스터는 노드와 컨테이너화된 애플리케이션을 실행 및 관리하는 집합이다. 쿠버네티스의 아키텍처는 (그림 2)와 같다.

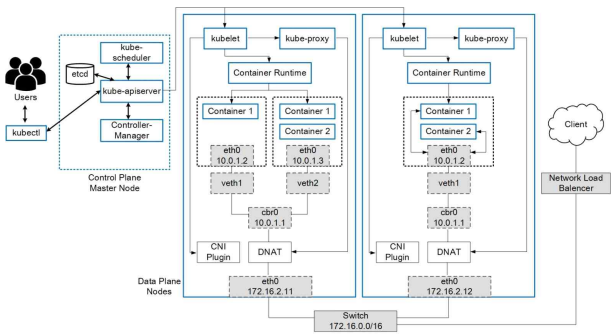


(그림 2) 쿠버네티스 아키텍처

쿠버네티스 아키텍처는 크게 제어 평면(Control Plane)과 데이터 평면(Data Plane)으로 나누어진다. 제어 평면은 클러스터 전체를 제어하는 평면으로써 시스템의 모든 데이터에 대한 기록을 유지하고 관리하기 위해 연속 제어 루프를 실행한다. 노드는 명령을 받고 실제 워크로드를 생성하여 서비스하는 컴포넌트이다. 데이터 평면은 실제 작업을 하는 평면으로 모든 노드에서 실행 중인 포드를 유지 관리하고 쿠버네티스 런타임 환경을 제공한다.

2.3 쿠버네티스 네트워크

쿠버네티스 네트워크 환경에서 동일한 포드 내의 컨테이너는 동일한 네임스페이스와 동일한 네트워크 인터페이스를 공유한다. 따라서, 로컬 호스트를 통해 직접 통신한다. 동일한 작업자 노드 내에서의 통신은 가상 이더넷(veth)과 브릿지(cbr0)을 통해 통신한다. 서로 다른 노드 내 통신은 오버레이 네트워크를 사용하여 통신하며, CNI 플러그인이 포드를 추적하고 각 네임스페이스에서 라우팅 규칙을 업데이트한다. 아래 (그림 3)은 쿠버네티스 네트워크 아키텍처를 나타낸다.



(그림 3) 쿠버네티스 네트워크 아키텍처

III. 쿠버네티스 환경에서의 보안 위협

본 장에서는 쿠버네티스 환경에서 발생 가능한 보안 위협에 대하여 분석하여 설명한다. 아래 [표 3]은 이를 요약하여 나타내었다.

3.1 kube-apiserver의 노출된 엔드포인트

kube-apiserver는 네트워크 외부에 API 엔드포인트를 노출해야 하는 유일한 컴포넌트이다. 포트를 공용 IP 주소에 노출시키고 클라이언트 및 기타 서버 모듈이 포트를 공용 IP 주소와 통신할 수 있도록 한다. 노출된 엔드포인트와 포트를 통해 인증되지 않은 사용자가 API 서버에 엑세스를 할 수 있고 이를 통한 권한 상승 공격이 발생 가능하다[3] [4] [5].

3.2 노드의 잘못 구성된 포트

데이터 평면의 모든 노드는 잘못된 포트를 구성할 시, 이를 대상으로 하는 공격이 발생할 수 있다. 공격자가 잘못 구성된 포트를 이용하여 노드를 손상시키고 모든 노드가 손상될 때까지 더 높은 권한으로 상승하여 다른 노드로 이동할 수 있다[4].

3.3 kubelet의 노출된 엔드포인트

kubelet API는 제어 평면의 API 서버와 컨테이너 런타임 사이의 연결 매체이다. 해당 kubelet API는 전용 클러스터 네트워크 내에서 노출된다. kubelet API는 클러스터의 모든 노드에서 엑세스할 수 있기 때문에 공격자는 클러스터 내에서 kubelet API에 대한 접근 권한을 요청 할 수 있고 접근 권한을 얻은 포드에서 공격자는 명령어를 실행할 수 있다[4].

3.4 컨테이너 런타임의 취약한 이미지 사용

컨테이너 런타임에 의해 실행되는 이미지를 통해 공격이 발생할 수 있다. 멀웨어가 내장되어 있는 이미지를 사용하여 컨테이너를 구축하게 될 경우, 컨테이너가 구축된 포드의 노드뿐만 아니라 쿠버네티스 클러스터 전체가 공격받을 위험이 존재한다[4].

3.5 컨테이너 런타임의 이미지 백도어

공격자가 합법적인 이미지를 다운로드 받고 백도어를 추가하여 공식 레포지토리에 업로드 한다면, 이미지 자체의 취약점이 없더라도 사용자가 이미지를 다운받았을 경우, 공격자는 백도어를 통해 간단히 포드에 엑세스할 수 있다. 따라서, 공격자는 접근 권한을 탈취할 수 있다[4].

3.6 컨테이너 런타임의 동일한 커널 공유

호스트에서 실행 중인 컨테이너의 경우, 호스트와 동일한 커널을 공유한다. 공격자는 공유된 커널을 사용하여 컨테이너를 탈출함으로써 호스트로 이동할 수 있다. 파일 시스템과 네트워크 소켓을 컨테이너에 마운트할 때에도 컨테이너 탈출이 일어날 수 있다[4] [7].

3.7 etcd 데이터의 암호화 부재

etcd에 엑세스할 수 있는 공격자는 클러스터를 정찰할 수 있다. 기본적인 쿠버네티스 설정은 비밀번호, SSH 키와 같은 민감한 데이터가 etcd에 base 64 인코딩을 통해 저장된다. base 64는 쉽게 해독될 수 있으므로 공격자가 etcd에 접근하였을 때, etcd의 모든 데이터를 볼 수 있다. 대부분의 클러스터는 작업자에게 etcd를 노출하지 않지만, 일부 클러스터는 오버레이 네트워크를 위한 Calico 네트워크 정책을 지원하기 때문에 별도의 etcd 인스턴스를 설치하여 etcd의 데이터가 유출될 수 있다[4].

3.8 제어 평면 통신에서의 보안 프로토콜 부재

제어 평면 컴포넌트 통신 사이에서 보안 조치가 이루어져 있지 않기 때문에 도청 공격이 발생할 수 있다[4].

3.9 포드 간 통신에서의 보안 프로토콜 부재

노드 내부의 포드 간 통신에는 포드를 연결하는 브릿지(cbr0)를 통해 통신한다. 해당 통신 방식에는 보안 조치가 이루어져 있지 않기 때문에 DNS 스푸핑, ARP 스푸핑과 같은 중간자 공격이 일어날 수 있다[4] [6].

[표 3] 쿠버네티스 환경에서 발생가능한 보안 위협

대상	보안 위협	공격	설명
kube-api server	노출된 엔드포인트	권한 상승	• 인증되지 않은 사용자가 API 서버에 엑세스하여 권한 상승 가능
노드	잘못 구성된 포트	권한 상승	• 잘못 구성된 포트를 이용하여 노드를 손상시키고 모든 노드가 손상될 때까지 더 높은 권한으로 상승하여 다른 노드 이동
kubelet	노출된 엔드포인트	접근 권한 탈취	• 공격자가 클러스터 내에서 API 요청을 하고 접근 권한을 얻어 명령어 실행
컨테이너 런타임	취약한 이미지	멀웨어	• 컨테이너 런타임이 취약한 이미지를 사용하여 멀웨어 감염
	이미지 백도어	접근 권한 탈취	• 공격자의 백도어가 설치된 이미지 사용하여 접근 권한 탈취
	동일한 커널 공유	컨테이너 탈출	• 호스트와 동일한 커널을 사용하여 컨테이너 탈출을 통해 호스트로 이동 가능
etcd	암호화 부재	데이터 유출	• etcd 데이터의 암호화 부재로 모든 데이터 유출
네트워크	보안 프로토콜 부재	도청	• 제어 평면 컴포넌트 통신에서 보안 조치가 이루어져 있지 않아 도청 가능
		중간자 공격	• 노드 내부의 포드 간 통신에서 보안 조치가 이루어져 있지 않아 ARP, DNS 스푸핑 가능

IV. 결론 및 향후 연구

본 논문에서는 쿠버네티스 환경에서 발생할 수 있는 보안 위협에 대하여 분석하였다. 본 논문에서 제시한 보안 위협들은 현재에도 발생하고 있고 점점 지능화되어가고 있다. 이에 대응하기 위해 향후 연구로 제시한 보안 위협에 대한 공격을 실증하고 지능화된 위협들에 대응하기 위한 보안 메커니즘을 설계할 수 있다.

ACKNOWLEDGMENT

이 논문은 2021년도 정부(과학기술정보통신부)의 재원으로 정보통신기획평가원의 지원을 받아 수행된 연구임 (No.2021-0-00796, 상시적 보안품질 보장을 위한 6G 자율보안 내재화 기반 기술 연구).

[참고문헌]

[1] "2021 Developer Survey", https://insights.stackoverflow.com/survey/2021, 2021년 11월 접속

[2] "Container Platform Market Share", https://www.t4.ai/industries/container-platform-market-share, 2021년 11월 접속

[3] Nadin Habbel, "Enhancing Availability of Microservice Architecture: A Case Study on Kubernetes Security Configurations", Digitala Vetenskapliga Arkivet, 2020.

[4] Mytilinakis, Panagiotis "Attack methods and defenses on Kubernetes", University of Piraeus Departent of Digital Systems, 2020.

[5] Linetskyi Artem, et al. "Eliminating privilage escalation to root in containers running on kubernetes", Scientific and practical cyber security journal, vol. 4, pp. 87-92, Mar 2020.

[6] Francesco Minna, et al. "Understanding the Security Implications of Kubernetes Networking", IEEE Security & Privacy, vol. 19, pp. 46-56, Oct 2021.

[7] Michael Reeves, et al. "Towards Improving Container Security by Preventing Runtime Escapes", IEEE Secure Development Conference (SecDev'21), Oct 2021.